Record-Level Security with ACLs: Lab Summary

1. Lab Objective

By completing this lab, learners understand how **script-controlled READ, WRITE, CREATE and DELETE ACLs** enforce record-level security, how **user roles** and **record field values** are evaluated together to make access decisions, and how ACLs protect sensitive data from unauthorized viewing, modification, creation and deletion across **forms, lists and Service Portal** interfaces.

2. What We Built

Component	Purpose
Roles bb1 - bb4	Custom roles, one for each operation, assigned to the EEE User
Table u_institution_details	Custom table holding student records with Branch (ECE, EEE, CSE)
Read ACL (bb1)	Controls who can view records; uses Branch is EEE condition and a script
Create ACL (bb2)	Controls who can add new records (New button)
Write ACL (bb3)	Controls who can edit existing records
Delete ACL (bb4)	Controls who can delete records

3. How an Access Decision Is Made

When a user tries to read, write, create or delete a record, ServiceNow evaluates the matching ACL. Access is granted only if **all** of the following pass:

- **Role check** - the user has the role listed in the ACL's Requires role list (for example bb1).
- **Data condition** - the record's field values match the condition (for example Branch is EEE).
- **Script** - the ACL script returns **true** (for example gs.hasRole('bb1') or gs.hasRole('admin')).

If any one of these fails, access is denied. This is why an EEE-branch user with bb1 sees only EEE records, while a user without the role sees nothing, and admin sees everything.

4. Effect of Each Operation

Operation	What it protects	Visible effect
Read	Viewing records and fields	Records appear or disappear in lists and forms
Create	Adding new records	New button is shown or hidden
Write	Modifying records	Fields become editable or read-only

Operation	What it protects	Visible effect
Delete	Removing records	Delete option is shown or hidden

5. Access by Role Combination

User	Result
No custom role	Cannot see any records
bb1	Can view only EEE branch records
bb1 + bb2	View EEE records and create new ones
bb1 + bb2 + bb3	View, create and edit EEE records
bb1 + bb2 + bb3 + bb4	View, create, edit and delete EEE records
Admin	Full access to all records regardless of branch

6. Where ACLs Apply

ACLs are enforced on the server, so the same rules protect data everywhere it is accessed:

- **Forms** - fields and buttons follow read and write rules.
- **Lists** - only records the user may read are returned; the New button follows the create rule.
- **Service Portal** - widgets that query the table return only permitted records.

Note: in this lab the script and Branch condition were added to the read ACL; the create, write and delete ACLs were role-based. The same script pattern can be added to those ACLs when stricter control is needed.

7. Key Learning Outcomes

- Create custom roles and assign them to users.
- Create a custom table with different field types, including Reference, Choice and Auto Number.
- Create record-level ACLs for read, write, create and delete.
- Use Requires role, Data condition and Script together in an ACL.
- Test access using impersonation and verify results for different users.
- Understand that ACLs protect data on forms, lists and Service Portal.

Best practices: give users only the roles they need (least privilege), always test by impersonating, and elevate to security_admin only when editing ACLs.

8. Resources

No resources available for this task.